



Roteiro de prática guiada

Nome: Arthur Saraiva de França Turma: 3B_____

Segurança, privacidade e conformidade

Contexto geral

Aplicações de chat com inteligência artificial lidam diretamente com informações fornecidas por usuários. Em muitos casos, essas informações incluem dados pessoais — como nome, e-mail, telefone e endereço — ou até dados sensíveis relacionados à saúde e a documentos oficiais.

Quando esses dados são enviados a um sistema de IA sem cuidado, existe risco real de exposição indevida, vazamentos e descumprimento de legislações como a LGPD (Lei Geral de Proteção de Dados) e o GDPR (General Data Protection Regulation). Por isso, sistemas responsáveis precisam adotar práticas que garantam segurança, privacidade e conformidade, mesmo quando utilizam tecnologias avançadas.

Princípios da LGPD aplicados a sistemas de IA

- **Finalidade:** uso dos dados para objetivo específico e legítimo.
- **Necessidade:** coletar apenas o mínimo necessário.
- **Adequação:** compatibilidade entre uso e finalidade informada.
- **Segurança:** adoção de medidas técnicas e administrativas de proteção.

Nesta atividade, você irá analisar como dados sensíveis podem ser protegidos em aplicações de chat, utilizando exemplos de mensagens estruturadas em formato JSON e técnicas de mascaramento e anonimização. Ao final, produzirá um registro descrevendo os riscos identificados e as medidas técnicas adotadas.

Estudo de caso: o chatbot de atendimento

Uma empresa implementou um chatbot com IA para atendimento ao cliente. Durante o uso, usuários começam a enviar informações sensíveis — CPF, dados médicos e documentos. Parte dessas mensagens é usada diretamente como



entrada para o modelo de IA; outras passam por tratamento antes de serem enviadas.

Exemplo de mensagem recebida pelo sistema (sem proteção):

```
{  
  "nome": "Maria Silva",  
  "cpf": "123.456.789-00",  
  "mensagem": "Preciso de ajuda com meu exame médico"  
}
```

Após aplicação de mascaramento (PII Masking):

```
{  
  "nome": "Maria S.",  
  "cpf": "***.***.***.***-**",  
  "mensagem": "Preciso de ajuda com meu exame médico"  
}
```

Situação fictícia produzida pela SEDUC-SP.

Tarefa 1 – Analise os exemplos e responda:

- a) Quais informações no JSON original representam risco à privacidade do usuário?

Apenas o CPF.

- b) Qual campo deveria ser completamente removido antes de ser enviado ao modelo? Por quê?

O Campo CPF.

- c) O mascaramento do CPF garante total segurança? Explique sua resposta.



Sim, garante a segurança de não vazar o CPF da pessoa, mas ainda fica o nome dela.

Conceitos-chave

Dados pessoais e dados sensíveis

Dados pessoais identificam ou tornam identificável uma pessoa natural (ex.: nome, e-mail, IP etc.). Dados sensíveis exigem proteção reforçada por envolverem informações de maior risco — como origem racial, convicções religiosas, dados de saúde, biometria e dados genéticos.

Anonimização e PII Masking

Anonimização é a técnica que remove ou transforma os dados de forma que não seja possível identificar o titular, mesmo com informações adicionais. Já o PII Masking (mascaramento de informações pessoalmente identificáveis) oculta ou substitui campos específicos por valores genéricos ou caracteres neutros antes que a mensagem seja processada pelo modelo de IA.

Exemplo comparativo:

Original: "cpf": "123.456.789-00"

Mascarado: "cpf": "***.***.***.***-**"

Anonimizado: campo removido por completo, pois não é necessário para a tarefa.

Logging seguro

Registrar eventos do sistema é essencial para auditoria, rastreamento de falhas e melhoria contínua. Porém, esses registros não devem armazenar dados sensíveis em texto aberto. Um log inseguro pode se tornar o próprio vetor de vazamento de dados.

Exemplo comparativo:

[SIS]

[U4]

[C6]



Log inseguro: [INFO] Usuário Maria Silva (CPF: 123.456.789-00) iniciou atendimento.

Log seguro: [INFO] Usuário ID-8472 iniciou atendimento.

LGPD e GDPR

Segurança e privacidade não são apenas boas práticas técnicas — são obrigações legais. A LGPD (Brasil) e o GDPR (União Europeia) estabelecem regras para coleta, armazenamento, uso e descarte de dados pessoais. Sistemas que violam essas normas podem gerar multas, danos à reputação e responsabilização jurídica.

Tarefa 2 – Classifique os dados a seguir:

Para cada item, indique se é dado pessoal (DP), dado sensível (DS) ou nenhum dos dois (N). Em seguida, indique a ação recomendada: manter, mascarar ou remover.

Dado	Classificação	Ação recomendada
Nome completo	DP	mascarar
Número do exame médico	N	remover
Cor favorita	N	remover
Endereço residencial	DS	mascarar
Religião declarada	N	remover
ID interno do atendimento	N	manter

Consolidação individual – Relatório explicativo

Com base no estudo de caso e nos conceitos discutidos, produza individualmente um relatório explicativo curto. Escreva com linguagem clara, organizada e técnica, entre 20 e 25 linhas.

Seu relatório deve abordar:



1. identificação dos dados sensíveis presentes no estudo de caso;
2. explicação de como a anonimização e o PII masking protegem o usuário;
3. importância do logging seguro e os riscos de um log mal configurado;
4. relação dessas práticas com a LGPD e o GDPR.

No estudo de caso, os principais dados sensíveis identificados foram o CPF e as informações relacionadas ao exame médico da usuária. O nome também é um dado pessoal e deve ser protegido para evitar a identificação da pessoa.

Para aumentar a segurança, podem ser utilizadas técnicas como PII Masking e anonimização. O PII Masking oculta parte das informações, enquanto a anonimização remove completamente os dados que não são necessários para a tarefa.

Outra medida importante é o logging seguro. Os logs ajudam a registrar eventos do sistema, mas não devem armazenar dados pessoais em texto aberto, pois isso pode causar vazamentos de informações.

Essas práticas estão relacionadas à LGPD e ao GDPR, que exigem a proteção dos dados pessoais dos usuários. Dessa forma, o uso de mascaramento, anonimização e logs seguros ajuda a garantir mais privacidade, segurança e conformidade com a legislação.

Critérios de avaliação do relatório

Após finalizar sua atividade, leia cada critério abaixo e marque a opção que melhor representa seu trabalho.

Critério	Conseguir realizar	Ainda preciso melhorar
-----------------	---------------------------	-------------------------------



Identifiquei corretamente os dados sensíveis presentes no estudo de caso.	Sim	☐
Expliquei como funcionam o PII masking e a anonimização na proteção de dados.	Sim	☐
Relacionei o logging seguro aos riscos de vazamento de informações.	Sim	☐
Conectei as práticas de segurança com as leis de proteção de dados (LGPD e GDPR).	Sim	☐
Meu texto está claro, organizado e objetivo.	Sim	☐